Sécurité de la fondation Google Cloud Platform

Ce document décrit la posture de sécurité robuste de votre fondation Google Cloud Platform (GCP). Il est divisé en deux domaines clés: les outils de sécurité avancés apportés par l'équipe de sécurité d'Ateko pour gérer et protéger de manière proactive votre environnement, et les mesures de sécurité fondamentales mises en œuvre par notre équipe de plateforme dédiée pour garantir une infrastructure cloud sécurisée et conforme dès sa conception.

Section 1: Outils de sécurité d'Ateko

L'équipe de sécurité d'Ateko s'appuie sur une suite de solutions de sécurité de pointe pour offrir une protection complète à votre environnement GCP. Ces outils offrent des capacités avancées pour la détection des menaces, la gestion des vulnérabilités et la surveillance de la posture de sécurité.

Gestion de la posture de sécurité du cloud (CSPM) avec CloudGuard

Pour garantir la sécurité et la conformité continues de votre environnement cloud, nous utilisons Check Point CloudGuard pour la gestion de la posture de sécurité du cloud (CSPM). CloudGuard offre une vue unifiée de votre posture de sécurité sur l'ensemble de vos actifs et services cloud.

Fonctionnalités clés:

- **Gouvernance et conformité automatisées:** CloudGuard surveille en permanence votre environnement GCP pour assurer la conformité avec les normes de l'industrie et les meilleures pratiques, ainsi qu'avec les politiques de sécurité spécifiques de votre organisation. Il propose des modèles de conformité prédéfinis pour des réglementations telles que PCI-DSS et HIPAA.
- **Détection des mauvaises configurations:** La plateforme identifie automatiquement les mauvaises configurations et les failles de sécurité dans vos ressources cloud, en fournissant des informations contextuelles sur les risques et en priorisant les problèmes détectés.
- **Correction automatisée:** CloudGuard permet la remédiation automatique des problèmes de sécurité identifiés, aidant à corriger rapidement les vulnérabilités et à maintenir une posture de sécurité solide.
- **Visibilité centralisée:** Il offre un tableau de bord unique pour visualiser et évaluer votre posture de sécurité, gérer la conformité et appliquer les meilleures pratiques de sécurité dans votre environnement multi-cloud.

Gouvernance opérationnelle et remédiation:

Afin d'assurer une couverture complète, un processus automatisé est en place pour intégrer de façon transparente tous les projets GCP nouvellement créés dans CloudGuard. L'équipe de sécurité d'Ateko surveille activement les alertes liées à la posture de sécurité générées par la plateforme. Cette surveillance est appuyée par une réunion hebdomadaire collaborative où les équipes plateforme et sécurité passent en revue le tableau de bord **CloudGuard Security Posture** afin de trier les anomalies. Lors de cette revue, les risques avérés (sévérité élevé, nombre élevé de resources impactées et n'est pas justifié par une décision) sont formellement consignés dans le système ITSM d'Ateko et assignés à l'équipe plateforme pour remédiation, tandis que les

anomalies non pertinentes sont marquées comme exclues avec une justification documentée (p. ex., des anomalies pointants une décision assumée et justifiée, telle que l'utilisation de clés gérées par Google plutôt que des clés CMEK).

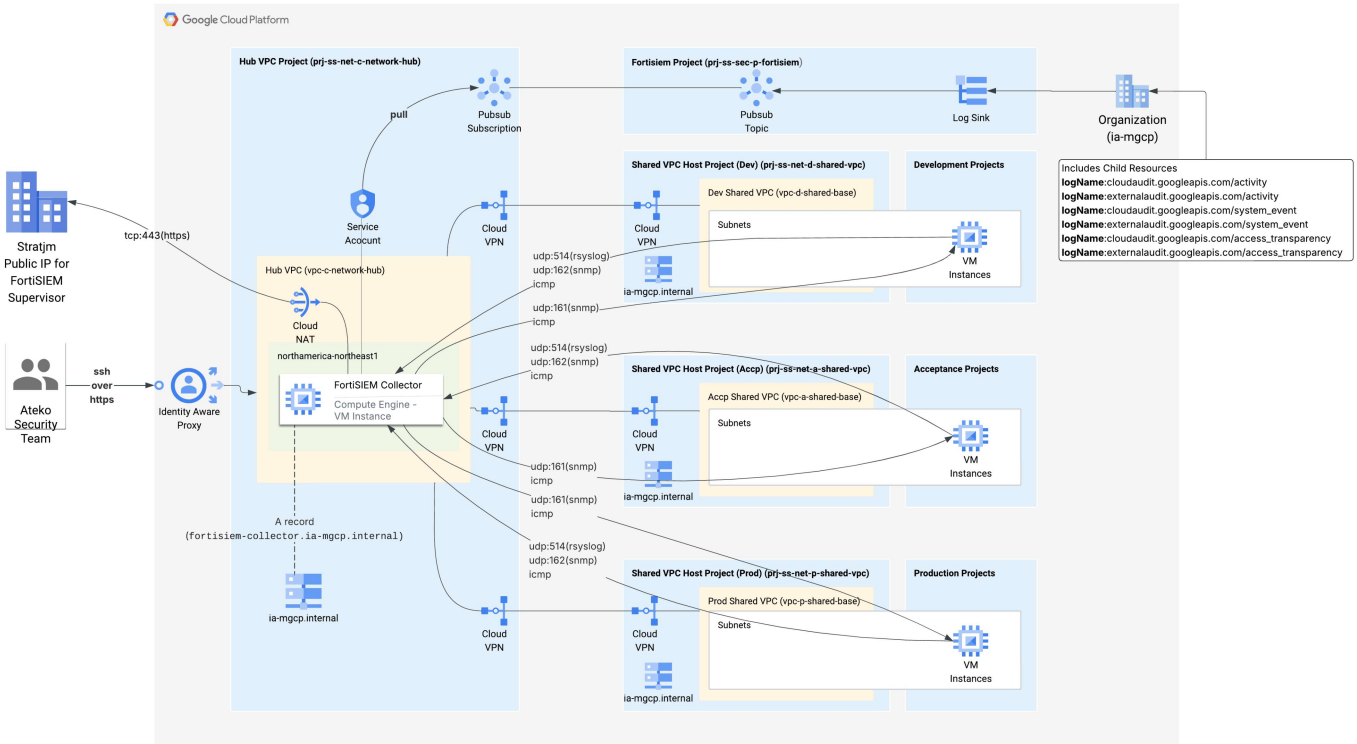
Gestion des informations et des événements de sécurité (SIEM) avec FortiSIEM

Nous utilisons FortiSIEM pour fournir des capacités complètes de gestion des informations et des événements de sécurité (SIEM). FortiSIEM offre une visibilité en temps réel de votre posture de sécurité en intégrant et en analysant les données provenant de diverses sources de sécurité.

Fonctionnalités clés:

- **Gestion unifiée de la sécurité et de la performance:** FortiSIEM combine la gestion des informations de sécurité avec la surveillance des performances en une seule plateforme, permettant l'analyse à la fois des menaces de sécurité et des métriques de performance du système.
- **Corrélation et analyse d'événements en temps réel:** En surveillant en continu l'activité du réseau et en corrélant les événements de plusieurs sources, FortiSIEM peut identifier des schémas indicatifs d'incidents de sécurité potentiels. Son puissant moteur d'analyse traite de vastes quantités de données pour fournir rapidement des informations exploitables.
- **Détection et réponse automatisées aux menaces:** FortiSIEM utilise un moteur d'analyse breveté pour la corrélation et l'alerte en temps réel, couplé à des renseignements sur les menaces provenant des FortiGuard Labs pour fournir des informations coordonnées et exploitables sur les menaces.

Architecture de FortiSIEM:



Ce qui est découvert et surveillé:

Protocole	Informations découvertes	Métriques collectées	Utilisé pour
SNMP	Nom d'hôte, matériel générique (CPU, mémoire, interface réseau, disque), logiciels (version du système d'exploitation, logiciels installés, processus en cours, ports TCP/UDP ouverts)	Disponibilité (Uptime), utilisation du CPU/Mémoire/Interface réseau/Espace disque, utilisation de l'espace d'échange (Swap), erreurs de l'interface réseau, nombre de processus en cours, changement de logiciel installé, utilisation CPU/mémoire des processus en cours, démarrage/arrêt des processus, état haut/bas des ports TCP/UDP	Surveillance des performances
Syslog	Fournisseur, Modèle	Journaux généraux incluant les succès/échecs d'authentification, les connexions privilégiées, la modification des utilisateurs/groupes	Surveillance de la sécurité et conformité

Collecte centralisée des journaux et revue opérationnelle:

Pour garantir une visibilité complète sur l'ensemble de l'organisation GCP, nous avons mis en place une architecture de journalisation centralisée. Les journaux d'activité, d'événements système et de transparence d'accès de tous les projets sont diffusés vers un sujet Google Cloud Pub/Sub central. Un collecteur FortiSIEM dédié, déployé dans le projet hub du réseau, s'abonne à ce sujet pour ingérer ces journaux et les transmettre au superviseur FortiSIEM pour analyse. Pour enrichir davantage les données, ce collecteur recueille également les journaux et les métriques directement depuis les instances de VM Compute Engine en utilisant rsyslog et SNMP.

Ce cadre technique est soutenu par une cadence opérationnelle disciplinée. Une réunion hebdomadaire est programmée entre l'équipe de sécurité et l'équipe de la plateforme pour examiner conjointement les alertes du superviseur. Ce forum est utilisé pour analyser les tendances en matière de sécurité, enquêter sur les incidents et affiner en continu les règles et politiques de détection du SIEM afin d'améliorer l'efficacité de la détection des menaces.

Gestion des vulnérabilités avec Tenable

Pour identifier et corriger de manière proactive les vulnérabilités au sein de votre infrastructure GCP, nous utilisons les solutions complètes de gestion des vulnérabilités de Tenable. Tenable offre une vue unifiée des vulnérabilités sur l'ensemble de votre surface d'attaque hybride. Des agents Tenable sont déployés sur toutes les instances de VM Compute Engine pour surveiller les vulnérabilités et l'application des correctifs sur les VM.

Fonctionnalités clés:

- **Gestion centralisée des vulnérabilités:** La plateforme native du cloud de Tenable offre une vue centralisée de vos données de vulnérabilité, hébergée et gérée par Tenable.
- **Analyse d'environnements hybrides:** Elle utilise une combinaison de scanners cloud pour les actifs publics et de scanners Nessus déployables pour les réseaux internes afin de fournir une analyse complète des vulnérabilités dans votre environnement hybride.
- **Priorisation basée sur le risque:** Le Vulnerability Priority Rating (VPR) de Tenable aide à prioriser les efforts de remédiation en identifiant les vulnérabilités qui ont été activement exploitées.

Analyse de code avec SonarCloud

Pour intégrer la sécurité directement dans le cycle de vie du développement et traiter les vulnérabilités à la source, nous utilisons SonarCloud pour l'analyse statique de code. Cette approche « shift-left » garantit que le code est sécurisé et fiable avant même d'être déployé dans les environnements de production.

Fonctionnalités clés:

- **Test de sécurité statique des applications (SAST):** SonarCloud analyse automatiquement le code source pour identifier les vulnérabilités de sécurité (telles que l'injection SQL, le cross-site scripting et les secrets non sécurisés), les bogues et les problèmes de qualité du code.
- **Intégration dans le pipeline CI/CD:** L'outil est entièrement intégré à nos pipelines d'intégration continue/livraison continue (CI/CD) sur Github et peut être utilisé par les équipes applicatives pour effectuer des analyses de code. Cela garantit que chaque commit de code et chaque pull request est automatiquement analysé, fournissant un retour immédiat aux développeurs.
- **Application de la porte de qualité (Quality Gate):** Cela agit comme un point de contrôle critique, faisant automatiquement échouer toute construction ou bloquant toute demande de fusion qui introduit de nouvelles vulnérabilités de haute sévérité ou ne respecte pas les normes de qualité prédéfinies. Cela empêche l'introduction de failles de sécurité dans la base de code.

Analyse des dépendances avec GitHub Dependabot

Pour gérer les risques de sécurité inhérents aux logiciels open-source et tiers, nous utilisons GitHub Dependabot pour l'analyse de la composition logicielle (SCA). Cela garantit que les dépendances utilisées dans nos applications sont maintenues à jour et exemptes de vulnérabilités connues.

Fonctionnalités clés:

- **Analyse automatisée des dépendances:** Dependabot surveille automatiquement les manifestes de dépendances dans nos dépôts GitHub (par exemple, `package.json`, `pom.xml`, `requirements.txt`) pour détecter les dépendances présentant des vulnérabilités de sécurité connues.
- **Alertes de vulnérabilité de sécurité:** Lorsqu'une dépendance vulnérable est identifiée, Dependabot génère une alerte de sécurité détaillée directement dans le dépôt, fournissant des informations sur la gravité et l'impact de la vulnérabilité.
- **Remédiation automatisée:** Pour de nombreuses vulnérabilités, Dependabot crée automatiquement une pull request (PR) pour mettre à jour le paquet non sécurisé vers la version minimale corrigée. Cela réduit considérablement le temps moyen de remédiation (MTTR) en fournissant aux développeurs un correctif prêt à être fusionné.

Détection et réponse des points de terminaison (EDR) avec Microsoft Defender for Cloud

Pour une protection avancée contre les menaces sur l'ensemble de vos charges de travail cloud hybrides, Ateko s'appuie sur Microsoft Defender for Cloud. Cette plateforme assure une sécurité complète de vos ressources GCP, y compris les serveurs et les conteneurs.

Fonctionnalités clés:

- **Protection multi-cloud native:** Microsoft Defender for Cloud offre un support natif pour GCP, permettant une gestion centralisée de la sécurité dans votre environnement multi-cloud.
- **Détection avancée des menaces:** Il fournit des capacités de détection et de réponse des points de terminaison (EDR) via Microsoft Defender for Endpoint, offrant un large éventail de services de sécurité

au-delà de l'antimalware traditionnel.
- **Protection des conteneurs et des serveurs:** Defender for Cloud offre une détection des menaces et des défenses avancées pour vos clusters Google Kubernetes Engine (GKE) Standard et vos machines virtuelles Google Compute Engine.

Section 2: Sécurité fondamentale de la plateforme

Notre équipe de plateforme a mis en œuvre un ensemble robuste de contrôles de sécurité et de meilleures pratiques au cœur de votre fondation GCP. Ces mesures sont conçues pour appliquer le principe du moindre privilège, gérer les accès de manière sécurisée et s'aligner sur les référentiels de sécurité reconnus par l'industrie.

Gestion des identités et des accès (IAM)

Nous appliquons une approche hautement structurée et automatisée de la gestion des identités et des accès, en respectant strictement les meilleures pratiques de Google Cloud et le principe du moindre privilège. L'accès n'est pas géré manuellement, mais est codifié et déployé via une base de référence robuste de politiques de groupe construite avec des modules Terraform. Cette méthodologie d'Infrastructure-as-Code (IaC) garantit que toutes les autorisations sont auditables, reproductibles et appliquées de manière cohérente.

Les capacités de cette base de référence automatisée incluent:

- La création et la gestion de groupes de sécurité au sein de Google Cloud.
- L'automatisation de l'ajout et du retrait d'utilisateurs de ces groupes.
- L'octroi et la révocation de rôles à des groupes à différentes portées dans la hiérarchie des ressources (organisation, dossier et projet).
- L'application de liaisons de rôles conditionnelles et granulaires à des groupes à n'importe quelle portée, permettant des contrôles d'accès contextuels.
- La gestion des autorisations sur des ressources critiques telles que les comptes de service et les comptes de facturation.

Ce cadre prend également en charge l'octroi d'un accès granulaire au niveau des ressources pour des services Google Cloud spécifiques, notamment:

- Les buckets Cloud Storage et les dossiers gérés
- Les sous-réseaux VPC
- Les ensembles de données BigQuery
- Les secrets de Secret Manager

Toute cette base de référence IAM est orchestrée via un fichier manifeste basé sur YAML. Ce manifeste fournit à l'équipe d'ingénierie de la plateforme une interface complète, centralisée et facile à utiliser pour gérer toutes les politiques IAM, garantissant à la fois agilité et gouvernance stricte:

```
infraBaseline: foundation-group-policies-lts
trigger: 1
terraformVars:
  project_id: group-policies
  groups_list:
    - name: <nom_du_groupe>
      description: <description_du_groupe>
      enable_external_collaborator: true
      members:
        - <adresse_email_utilisateur>
      roles_org:
        - roles/resourcemanager.<nom_du_role>
      conditional_roles_org:
        - role: roles/resourcemanager.<nom_du_role>
          title: <titre_liaison_role_conditionnelle>
          description: <description_liaison_role_conditionnelle>
          expression: "<expression_liaison_role_conditionnelle>"
      roles_folders:
        "<id_dossier>":
          - roles/resourcemanager.<nom_du_role>
      conditional_roles_folders:
        - role: roles/resourcemanager.<nom_du_role>
          title: <titre_liaison_role_conditionnelle>
          description: <description_liaison_role_conditionnelle>
          expression: "<expression_liaison_role_conditionnelle>"
          folder: '<id_dossier>'
      roles_projects:
        "<id_projet>":
          - roles/resourcemanager.<nom_du_role>
      conditional_roles_projects:
        - role: roles/resourcemanager.<nom_du_role>
          title: <titre_liaison_role_conditionnelle>
          description: <description_liaison_role_conditionnelle>
          expression: "<expression_liaison_role_conditionnelle>"
          project: '<id_projet>'
      roles_buckets:
        "<uri_bucket_gcs>":
          - roles/resourcemanager.<nom_du_role>
      roles_service_accounts:
        "serviceAccount:<adresse_email_compte_de_service>":
          - roles/resourcemanager.<nom_du_role>
      roles_billing_accounts:
        "<id_compte_de_facturation>":
          - roles/resourcemanager.<nom_du_role>
      roles_subnets:
        "<id_sous_reseau>":
          - roles/resourcemanager.<nom_du_role>
      roles_bq_datasets:
        "<id_ensemble_de_donnees>":
          - roles/resourcemanager.<nom_du_role>
      roles_secrets:
        "<id_secret>":
```

```
      - roles/resourcemanager.<nom_du_role>
  gcs_managed_folders:
    "<uri_bucket_gcs>":
      "<nom_dossier_gere>":
        - roles/resourcemanager.<nom_du_role>
```

Références:

- Documentation Google sur IAM (https://docs.cloud.google.com/iam/docs/overview)
- Baseline IAM dans Github* (https://github.com/ia-mgcp/ia-iac-platforms/tree/main/terraform/infra/foundation-group-policies-lts)

**Note: Un accès à l'organisation Github ia-mgcp est requis pour visualiser ce dépôt*

Intégration du cycle de vie des identités: Avant que toute autorisation puisse être accordée dans GCP, l'identité d'un utilisateur doit d'abord être provisionnée dans Google Cloud Identity. Ceci est accompli via un processus de synchronisation d'identité géré depuis votre tenant Entra ID. La synchronisation est pilotée par l'appartenance à des groupes de sécurité, garantissant que seuls les utilisateurs approuvés sont provisionnés dans l'environnement cloud. (Remarque: Les processus de fédération d'identité pour votre organisation et la nôtre sont distincts, car chaque entité conserve son propre fournisseur d'identité).

Accès juste-à-temps (JIT) et gestion des accès privilégiés (PAM)

Pour atténuer les risques associés aux privilèges permanents, nous utilisons le Gestionnaire d'accès privilégié (PAM) de Google Cloud pour mettre en œuvre un accès juste-à-temps (JIT). Cela fait passer le modèle de sécurité de permissions « toujours actives » à des élévations d'accès à la demande, limitées dans le temps et basées sur l'approbation.

La gestion des accès privilégiés n'est pas effectuée manuellement mais est entièrement automatisée via un module de base de référence Terraform robuste et dédié. Cette approche d'Infrastructure-as-Code (IaC) nous permet de définir les habilitations PAM avec un contrôle granulaire, en spécifiant des paramètres clés tels que:

- La portée de l'habilitation (organisation, dossiers ou projets).
- Le flux d'approbation requis.
- Les utilisateurs et groupes éligibles pour être demandeurs.
- La durée maximale pour l'octroi d'un accès.
- L'option d'auto-approbation pour des rôles spécifiques à faible risque.
- Des configurations de notification personnalisées.

Comme pour notre cadre IAM, ces habilitations sont déclarées dans un fichier manifeste basé sur YAML. Cela fournit à l'équipe de la plateforme une méthode claire, versionnée et auditable pour gérer toutes les politiques d'accès JIT dans l'environnement:

```
infraBaseline: foundation-pam
terraformVars:
  project_id: pam
  pam_config:
    - name: <nom_habilitation>
      max_request_duration: "<duree_en_secondes>"
      parent_id: <id_parent>
      auto_approve: true
      requestors:
        - "<nom_groupe>"
      folder_level_roles:
        - role: "roles/resourcemanager.<nom_du_role>"
      organization_level_roles:
        - role: "roles/resourcemanager.<nom_du_role>"
      all_level_roles:
        - role: "roles/resourcemanager.<nom_du_role>"
```

Références:

- Documentation Google sur PAM (https://docs.cloud.google.com/iam/docs/pam-overview)
- Baseline PAM dans Github* (https://github.com/ia-mgcp/ia-iac-platforms/tree/main/terraform/infra/foundation-pam)

**Note: Un accès à l'organisation Github ia-mgcp est requis pour visualiser ce dépôt*

Revue d'accès automatisée et conformité

Afin d'assurer une gouvernance continue et de faciliter la conformité, une revue complète des accès est réalisée via un processus entièrement automatisé. Sur une base mensuelle, ce processus extrait de manière programmatique un large éventail de données de sécurité et de configuration provenant de l'ensemble des organisations GCP et Github, notamment:

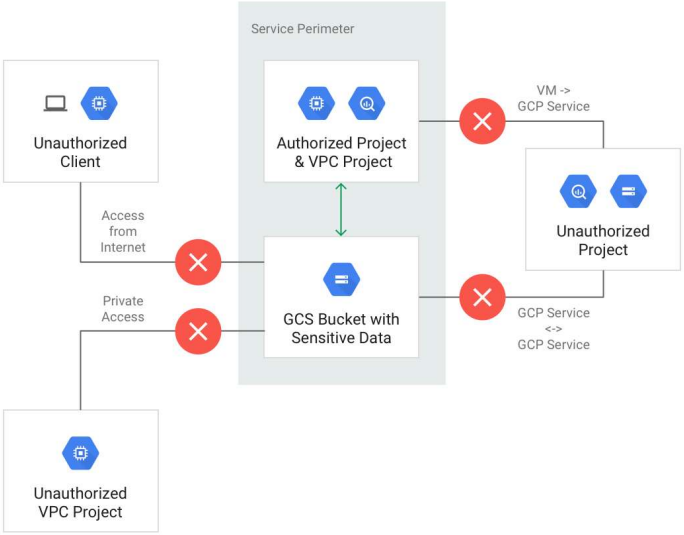
- **Accès des principaux GCP:** Appartenances aux groupes, liaisons de rôles des groupes et liaisons de rôles directes des utilisateurs.
- **État des identités de service GCP:** Un inventaire complet des comptes de service, de leurs clés associées et de leurs liaisons de rôles, ainsi que des liaisons de rôles des agents de service.
- **Métadonnées et contexte GCP:** Des métadonnées riches pour les groupes (description, nombre de membres, nombre de liaisons), les utilisateurs (nombre de liaisons), les comptes de service (nombre de liaisons) et les agents de service (nombre de liaisons).
- **Accès privilégié GCP:** Un rapport de toutes les habilitations du Gestionnaire d'accès privilégié (PAM) et des métadonnées d'utilisation des 30 derniers jours.
- **Politique et structure des ressources GCP:** Un inventaire complet des rôles personnalisés, des structures de dossiers, des métadonnées de projet, des politiques d'organisation et des politiques de refus (Deny Policies).
- **Accès et structure Github:** Un inventaire complet des dépôts Github et de leurs métadonnées, des équipes Github et de leurs métadonnées, des appartenances des utilisateurs, des métadonnées des utilisateurs et des liaisons de rôles personnalisées. Des vues supplémentaires croisent les données pour

fournir des informations précieuses et analytiques afin d'effectuer une gouvernance efficace sur l'ensemble de l'organisation Github.

Pour plus de détails sur ce processus, veuillez consulter la documentation associée: Auditabilité des actifs et des accès GCP et Github (./AuditabiliteActifsAcces.md)

Contrôles de service VPC (VPC-SC)

Pour fournir une couche de défense essentielle contre l'exfiltration de données, l'équipe de la plateforme utilise les Contrôles de service VPC (VPC Service Controls). Cela crée un périmètre de sécurité virtuel autour des projets Google Cloud spécifiés et des services gérés qu'ils contiennent, tels que BigQuery et Cloud Storage. Ce périmètre fonctionne comme un pare-feu au niveau du service, isolant les ressources et les données de l'internet public et des menaces internes. Par défaut, la communication est bloquée à travers le périmètre, atténuant les risques liés aux identifiants volés, au code compromis ou aux politiques IAM mal configurées. L'accès n'est autorisé qu'à partir de réseaux et d'identités autorisés, garantissant que vos données sensibles restent dans leur périmètre sécurisé désigné.



Pour s'aligner sur la structure organisationnelle, chaque unité commerciale (représentée par un dossier de premier niveau) est protégée par son propre périmètre par défaut dédié, qui sécurise toutes les API de service prises en charge dans les projets de cette unité. Ce périmètre fonctionne comme un pare-feu au niveau du service, isolant les ressources et les données par défaut et atténuant les risques liés aux identifiants volés, au code compromis ou aux politiques IAM mal configurées.

La création et la gestion du cycle de vie de ces périmètres sont entièrement automatisées à l'aide d'un module de base de référence Terraform robuste. Cette approche d'Infrastructure-as-Code (IaC) offre un contrôle granulaire sur la configuration du périmètre, y compris la capacité de gérer par programmation:

- L'ajout ou le retrait de projets du périmètre.
- La liste des API de service protégées.
- Des politiques d'entrée (ingress) et de sortie (egress) détaillées pour contrôler les flux de données.
- Une configuration de « simulation » (dry-run) pour tester en toute sécurité les changements de politique sans les appliquer.

Cette puissante base de référence Terraform est orchestrée via un fichier manifeste déclaratif basé sur YAML. Cette abstraction fournit une méthode lisible et facile à utiliser pour configurer et gérer chaque périmètre par le code, ce qui améliore considérablement l'auditabilité, la reproductibilité et la gouvernance:

```
infraBaseline: vpc-service-control
terraformVars:
  parent_policy_id: "<id_politique_parente>"
  perimeter_name: <nom_perimetre>
  description: "<description_perimetre>"
  resources:
    - <id_projet>
  resources_dry_run:
    - <id_projet>
  restricted_services:
    - <nom_api>.googleapis.com
  restricted_services_dry_run:
    - <nom_api>.googleapis.com
  access_levels:
    - <nom_niveau_acces>
  access_levels_dry_run:
    - <nom_niveau_acces>
  ingress_policies:
    - title: "<nom_politique_entree>"
      from:
        identity_type:
        identities:
        sources:
          access_levels:
      to:
        resources:
        operations:
          "<nom_api>.googleapis.com":
            methods:
            permissions:
  ingress_policies_dry_run:
    - title: "<nom_politique_entree>"
      from:
        identity_type:
        identities:
        sources:
          access_levels:
      to:
        resources:
        operations:
          "<nom_api>.googleapis.com":
            methods:
            permissions:
  egress_policies:
    - title: "<nom_politique_sortie>"
      from:
        identity_type:
        identities:
        sources:
      to:
        resources:
        operations:
```

```
          "<nom_api>.googleapis.com":
            methods:
            permissions:
  egress_policies_dry_run:
    - title: "<nom_politique_sortie>"
      from:
        identity_type:
        identities:
        sources:
      to:
        resources:
        operations:
          "<nom_api>.googleapis.com":
            methods:
            permissions:
```

Par défaut, tous les périmètres VPC-SC sont configurés avec un niveau d'accès standard. Cette politique cruciale garantit que le trafic entrant n'est autorisé qu'à partir d'un ensemble pré-approuvé de réseaux de confiance ou de sources légitimes identifiées qui nécessitent un accès. Cela applique un modèle « tout refuser, autoriser par exception », garantissant que vos données sensibles restent en sécurité dans leur périmètre désigné.

Pour garantir l'intégrité de ces périmètres, l'équipe de la plateforme surveille activement un tableau de bord dédié aux violations de VPC-SC. Cela offre une visibilité quasi temps réel sur toute tentative bloquée d'accès à des ressources protégées depuis l'extérieur du périmètre ainsi que toute tentative bloquée d'accès à des ressources protégées depuis l'intérieur du périmètre. Ce tableau de bord est un outil essentiel pour détecter les violations de sécurité potentielles et aide grandement à l'analyse et au dépannage nécessaires pour affiner les politiques d'entrée/sortie et enquêter sur les activités anormales.

Références:

- Documentation Google sur VPC-SC (http://docs.cloud.google.com/vpc-service-controls/docs/overview)
- Baseline VPC-SC sur Github* (https://github.com/ia-mgcp/ia-iac-platforms/tree/main/terraform/infra/vpc-service-control-lts)

**Note: Un accès à l'organisation Github ia-mgcp est requis pour visualiser ce dépôt*

Gestion des mauvaises configurations, des vulnérabilités et des menaces

Le programme de sécurité de la plateforme d'Ateko s'articule autour de trois piliers essentiels d'un environnement cloud sain: la **Gestion des mauvaises configurations**, la **Gestion des vulnérabilités (CVE)** et la **Détection active des menaces**. En surveillant ces éléments distincts via le Security Command Center (SCC) de Google, nous nous assurons que les signaux critiques sont traités rapidement afin de minimiser les risques pour iA.

Stratégie de réponse aux incidents et de remédiation automatisée

Pour assurer une remédiation rapide des risques réels, nous utilisons un flux de travail automatisé qui exporte continuellement les nouvelles anomalies du SCC et crée des incidents dans le système ITSM d'Ateko. Afin de concentrer les efforts sur les problèmes les plus urgents, nous appliquons un filtre strict qui déclenche des incidents uniquement pour les anomalies **actives** et **non muettes** (unmuted) correspondant aux critères suivants:

- **Mauvaises configurations ou Menaces** classées comme de sévérité **Élevée** ou **Critique**.
- **Vulnérabilités** dont l'impact CVE est **Critique**.

En complément de cette automatisation, nous employons une boucle de rétroaction continue pilotée par des **simulations d'attaques** et un **processus de surveillance mensuel**. Cela nous permet d'identifier et de prioriser les efforts de remédiation les plus précieux qui réduisent efficacement la surface d'attaque et améliorent notre posture de conformité.

Rapports mensuels de conformité et de gouvernance

Notre posture de conformité actuelle est alignée sur le **CIS Google Cloud Platform Foundation Benchmark v2.0**, et elle peut être adaptée à n'importe quelle norme de conformité spécifique de Google Cloud.

Pour l'auditabilité et la planification stratégique, nous automatisons l'exportation d'un dossier de conformité Excel détaillé, livré au canal Teams d'iA suivant: audits - Google Cloud Platform (mailto:553b7c3a.ia.ca@ca.teams.ms) sur une base mensuelle (le 1er du mois). Ce rapport consolide les données du SCC avec nos registres de gouvernance internes via quatre onglets distincts:

- **Findings (Anomalies):** Une vue complète des risques actifs contenant les données du SCC (Catégorie, Sévérité, Détails de la ressource, Projet et Classe du constat). De manière cruciale, cet onglet inclut des colonnes déduites (`exception_id` , `remediation_id`) qui font référence à nos registres de gouvernance, permettant au client de voir instantanément si un constat a une exception associée ou un plan de remédiation en place.
- **Exceptions:** Cet onglet fournit une piste d'audit complète des risques acceptés. Il est alimenté via un **flux de travail GitOps** où les exceptions sont gérées dans un fichier `cspm_exception_register.yaml` stocké dans le dépôt de la plateforme. Les modifications apportées à ce fichier sont automatiquement chargées dans BigQuery, assurant le contrôle de version. L'exportation détaille la *Justification, les Contrôles compensatoires, l'Identité de l'approbateur, la Date d'approbation, la Date d'expiration* et la *Fréquence de révision*.
- **Planned Remediation (Remédiation planifiée):** Similaire aux exceptions, cet onglet suit les correctifs à long terme gérés via un fichier `cspm_planned_remediation_register.yaml` . Il permet à l'équipe Plateforme de planifier le travail de manière transparente, affichant la *Description de la remédiation planifiée, la Priorité (0-3), l'Équipe responsable, le Trimestre cible d'achèvement* et les *Contraintes connues*.
- **Reference Category (Catégorie de référence):** Conçu pour les auditeurs et les parties prenantes non techniques, cet onglet agit comme un dictionnaire. Il liste chaque catégorie potentielle de constat (p. ex., `API_KEY_EXISTS`) accompagnée de son explication officielle et de son contexte provenant du SCC, garantissant que toutes les parties comprennent la nature des risques surveillés.

Dernière modification de cette page le 3/10/2026 6:42:16 PM +00:00 (UTC).